Vulnerability Mitigation Classification Standards

Impact	Definition
Critical	Complete system compromise. Requires immediate attention.
High	Limited or complete system or service compromise is possible.
Moderate	Possible to cause interruptions to system and/or service availability and could provide information that can be used in attacks of greater impact.
Low	Discloses publicly accessible information that could be used in higher impact attacks.
Informational	Purely data-driven information on host attributes.

Likelihood	Definition
Critical	No permissions or network controls are present to prevent this vulnerability.
High	Vulnerabilities do not require elevated permissions to execute. Target system has little to no network/mitigating controls.
Moderate	System can be accessed by regular users of the network and may require elevated permissions.
Low	Requires system or administrator level access to the system and the system is not publicly accessible.
Informational	Purely data-driven information on host attributes.

Severity	CVSS V3 Range	Definition
Critical	9.0-10	Complete system compromise. Requires immediate attention.
High	7.0-8.9	Exploitation could result in unauthorized system access and elevation of privileges. System availability could also be impacted.
Moderate	4.0-6.9	Vulnerabilities that could lead to sensitive information disclosure and are likely to be used to chain attacks of greater severity if left unmitigated.
Low	0.1-3.9	Vulnerabilities that won't compromise the network on their own but could provide information on other areas that may allow chaining of higher severity vulnerabilities.
Informational	N/A	Purely data driven information on host attributes.

		LIKELIHOOD			
IMPACT	RATING	Low	Moderate	High	Critical
	Low	Low	Moderate	Moderate	High
	Moderate	Moderate	Moderate	High	High
	High	Moderate	High	High	Critical
	Critical	High	High	Critical	Critical

FINDING #1	Outdated OpenSSH Version - 6.6.1p1
HOST NAME	10.10.3.31
IP ADDRESS	10.10.3.31

LIKELIHOOD	IMPACT	SEVERITY
High	High	High

DESCRIPTION

OpenSSH (Open Secure Shell) is a free, open-source suite of tools that allows you to securely connect to and manage remote systems over a network. It was created as a secure replacement for older, insecure methods like Telnet and FTP. Although OpenSSH itself is secure when kept current, our scan found the host is running a significantly old version. Its security relies heavily on regular updates, as older versions can contain unpatched vulnerabilities.

During the scan, the security assessment identified that the target host is running OpenSSH version 6.6.1p1 Ubuntu 2ubuntu2.13, which was released in 2014. This version is significantly outdated and contains multiple known security vulnerabilities that have been publicly disclosed and patched in subsequent releases.

OpenSSH 6.6.1p1 is vulnerable to several critical security issues, including but not limited to:

CVE-2016-0777 and CVE-2016-0778 (roaming_common.c vulnerabilities): These vulnerabilities in the OpenSSH client can lead to information disclosure and potential private key leakage. An attacker controlling a malicious SSH server could exploit these flaws to extract sensitive information from the client's memory, including private SSH keys.

CVE-2015-5600 (MaxAuthTries bypass): This vulnerability allows remote attackers to conduct brute-force attacks more effectively by bypassing the MaxAuthTries limit through the keyboard-interactive authentication method. This significantly increases the risk of unauthorized access through credential stuffing or password guessing attacks.

CVE-2015-6564 (Use-after-free vulnerability): A use-after-free vulnerability in the mm_answer_pam_free_ctx function could potentially be exploited by attackers to cause denial of service or possibly execute arbitrary code.

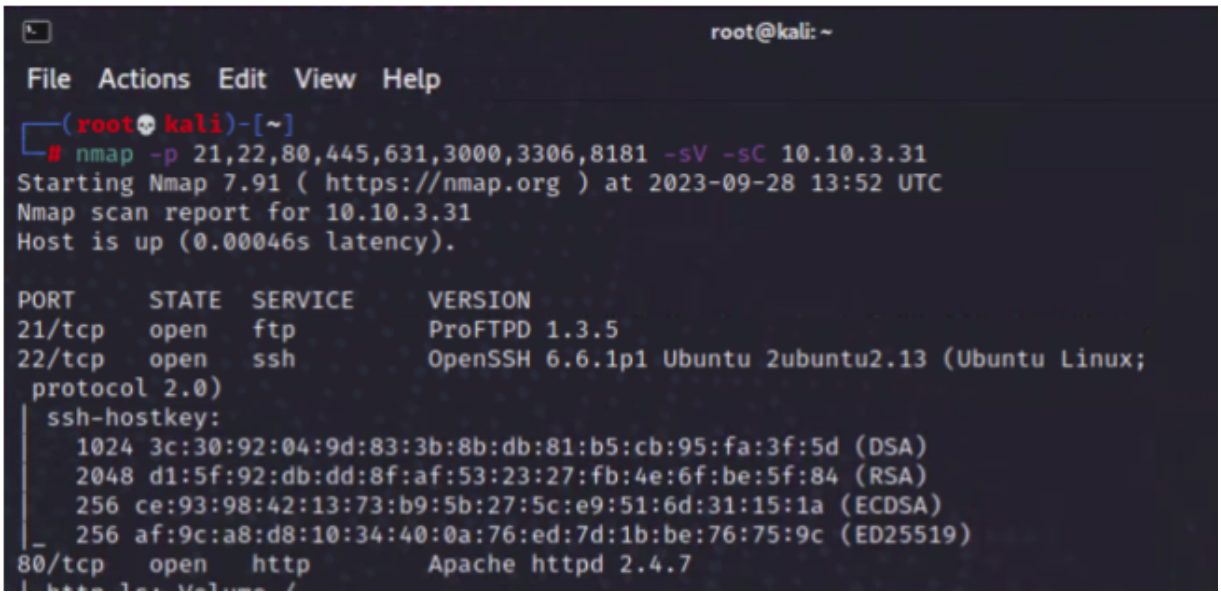
Running an outdated SSH service exposes the organization to significant security risks, as SSH is a critical remote access service that provides administrative access to systems. Successful exploitation could lead to:

- Unauthorized remote access to the server
- Credential theft and lateral movement within the network

- Information disclosure including sensitive authentication data
- Complete system compromise through privilege escalation
- Data breaches and compliance violations

The presence of outdated SSH versions is a common target for automated scanning tools used by threat actors, making this host a high-priority target for exploitation.

VALIDATION



REMEDIATION

Immediate Actions:

1. **Upgrade OpenSSH to the latest stable version** (currently 9.x series or the latest available for your Ubuntu distribution):

2. Review and harden SSH configuration (`/etc/ssh/sshd_config`):

- Disable root login: `PermitRootLogin no`
- Use key-based authentication: `PubkeyAuthentication yes`
- Disable password authentication if possible: `PasswordAuthentication no`

- Limit user access: `AllowUsers [specific-users]`
- Change default port if appropriate: `Port [non-standard-port]`
- Disable protocol 1: `Protocol 2`
- Set strong ciphers and MACs
- Enable strict mode: `StrictModes yes`

3. **Implement additional security controls:**

- Configure firewall rules to restrict SSH access to known IP addresses
- Implement fail2ban or similar intrusion prevention systems
- Enable two-factor authentication (2FA) for SSH access
- Monitor SSH logs for suspicious activity
- Use SSH jump hosts or bastion servers for administrative access

4. **After making changes, restart the SSH service**

REFERENCES		
MITRE ID	**TECHNIQUE NAME**	**DESCRIPTION**
T1021.004	Remote Services: SSH	Adversaries may use Valid Accounts to log into remote machines using Secure Shell (SSH). The adversary may then perform actions as the logged-on user. SSH is a protocol that allows authorized users to open remote shells on other computers. Many Linux and macOS versions come with SSH installed by default.
T1110	Brute Force	Adversaries may use brute force techniques to gain access to accounts when passwords are unknown or when password hashes are obtained. Without knowledge of the password for an account or set of accounts, an adversary may systematically guess the password using a repetitive or iterative mechanism.
T1595.00	Active Scanning: Vulnerability Scanning	Adversaries may scan victims for vulnerabilities that can be used during targeting. Vulnerability scans typically check if the configuration of a target host/application is vulnerable to a specific exploit.
MITRE ID	**MITIGATION NAME**	**DESCRIPTION**

M1051	Update Software	Perform regular software updates to mitigate exploitation risk. Keeping software up to date, particularly security software, is critical to preventing exploitation of known vulnerabilities.
M1032	Multi-factor Authentication	Use two or more pieces of evidence to authenticate to a system; such as username and password in addition to a token from a physical smart card or token generator.
M1035	Limit Access to Resource Over Network	Prevent access to file shares, remote access to systems, unnecessary services. Mechanisms to limit access may include use of network concentrators, RDP gateways, etc.

TECHNICAL ARTICLES

CVE REFERENCES:

- **CVE-2016-0777** - Information Disclosure (CVSS 4.3) https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2016-0777
- **CVE-2016-0778** - Information Disclosure (CVSS 4.3) https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2016-0778
- **CVE-2015-5600** - Authentication Bypass (CVSS 8.5) https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-5600
- **CVE-2015-6564** - Use-after-free (CVSS 6.5) https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-6564

TECHNICAL ARTICLES:

- https://attack.mitre.org/techniques/T1021/004/
- https://www.openssh.com/security.html
- https://ubuntu.com/security/notices